

# PBL 02: IAM 및 S3 버킷 정책 분석을 통한 권한 평가 보고서

정하은

## 1. 개요

본 보고서는 특정 IAM 사용자 user01에게 부여된 IAM 정책(Identity-based Policy)과 S3 버킷 정책(Resource-based Policy)을 분석하여, user01이 S3 서비스 내에서 수행할 수 있는 권한 범위를 평가하는 것을 목적으로 한다.

## 2. 문제 정의 및 요구사항

IAM 사용자 user01에게 다음과 같은 IAM 정책과 S3 버킷 정책이 부여되었다.

- **목표** : user01이 이 두 가지 정책 조합 하에서 어떤 S3 작업을 수행할 수 있는지, 없는지를 파악한다.
- **평가 항목 예시** : EC2 생성 및 상세 내용 보기, S3 버킷 생성 및 목록 보기, S3 버킷에 객체 업로드 및 다운로드 등 (S3 관련 작업에 집중)

### 부여된 정책 상세

#### 1) IAM 정책

```
{
  "Effect": "Allow",
  "Action": "s3*",
  "Resource": "*"
}
```

#### 2) S3 버킷 정책 (특정 S3 버킷에 연결)

```
{
  "Effect": "Deny",
  "Principal": "user01",
  "Action": "s3:PutObject",
  "Resource": "*"
}
```

### 3. AWS 정책 평가 이해

AWS 환경에서 권한 평가는 IAM 정책과 리소스 정책이 복합적으로 작용하며, 다음과 같은 원칙을 따른다.

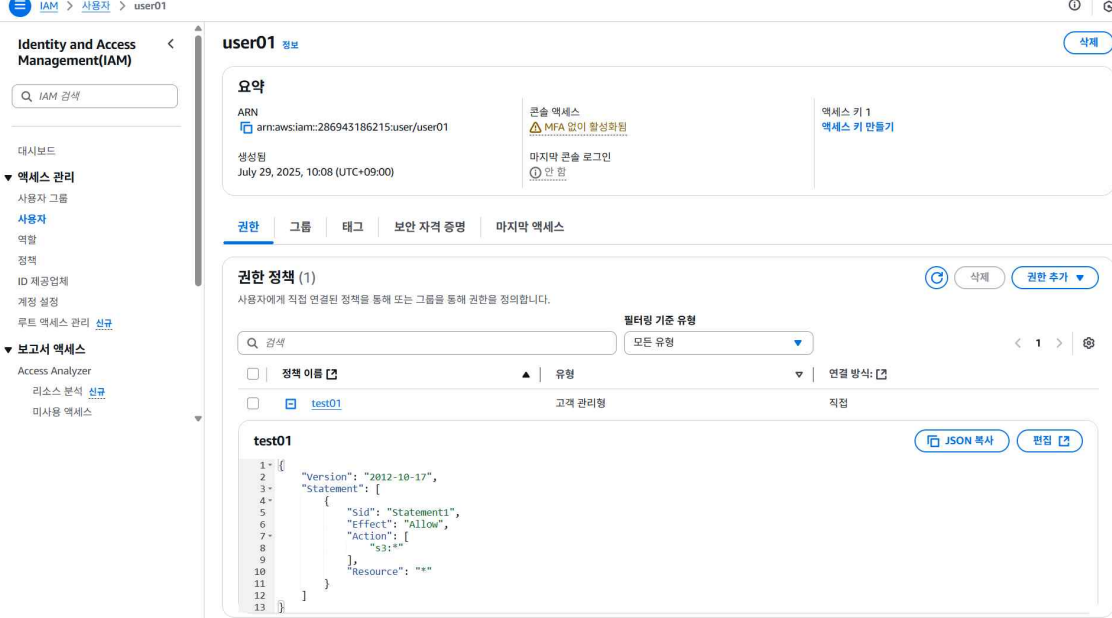
- IAM 정책 : IAM 사용자, 그룹, 역할 등 "누구"에게 어떤 권한을 부여할지 정의한다.
- 리소스 정책 : 특정 리소스에 "누구"가 접근하여 어떤 작업을 할 수 있는지 정의한다.
- 명시적 거부(Explicit Deny)의 우선순위 : AWS 정책 평가에서 가장 중요한 규칙은 "명시적 Deny는 모든 Allow를 재정의한다"는 것이다. 즉, 어떤 정책에서라도 특정 작업이 명시적으로 Deny되었다면, 다른 정책에서 해당 작업이 Allow되어 있더라도 최종적으로는 거부된다. 명시적인 Allow가 없으면 기본적으로 접근은 거부된다.

### 4. user01 권한 분석

주어진 IAM 정책과 S3 버킷 정책을 위의 정책 평가 원칙에 따라 분석한다.

#### 4.1. IAM 정책 분석

```
{
  "Effect": "Allow",
  "Action": "s3*",
  "Resource": "*"
}
```



The screenshot shows the AWS IAM console for the user 'user01'. The policy 'test01' is highlighted. The policy document is displayed in JSON format:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "statement1",
      "Effect": "Allow",
      "Action": [
        "s3:*"
      ],
      "Resource": "*"
    }
  ]
}
```

user01에게 부여된 이 IAM 정책은 user01이 모든 S3 서비스(s3\*)의 모든 리소스(\*)에 대해 어떠한 제한 없이 모든 작업을 수행할 수 있도록 명시적으로 허용하고 있다. 이 정책만으로는 user01이 S3와 관련된 모든 API 호출(버킷 생성, 객체 업로드/다운로드/삭제, 버킷 설정 변경 등)을 할 수 있음을 의미한다.

## 4.2. S3 버킷 정책 분석

```
{
  "Effect": "Deny",
  "Principal": "user01",
  "Action": "s3:PutObject",
  "Resource": "*"
}
```

S3 버킷에 부여된 이 정책은 Principal이 user01인 경우, 모든 S3 리소스(\*)에 대해 s3:PutObject 작업(객체 업로드)을 명시적으로 거부하는 것이다. 이는 특정 버킷에만 적용되는 것이 아니라, user01이 접근할 수 있는 모든 S3 리소스에 대해 PutObject 권한을 제한하겠다는 것이다.

Amazon S3 > 버킷 > buckethj0729

버킷 정책을 편집했습니다.

buckethj0729 정보

객체속성권한지표관리액세스 지점

권한 개요

액세스 찾기

액세스 조사 결과는 IAM 외부 액세스 분석기에서 제공됩니다. IAM 분석기 조사 결과가 작동하는 방식에 대해 자세히 알아보세요.

ap-northeast-1에 대한 분석기 보기

퍼블릭 액세스 차단(버킷 설정)

편집

퍼블릭 액세스는 ACL(액세스 제어 목록), 버킷 정책, 액세스 지점 정책 또는 모두를 통해 버킷 및 객체에 부여됩니다. 모든 S3 버킷 및 객체에 대한 퍼블릭 액세스가 차단되었는지 확인하려면 [모든 퍼블릭 액세스 차단]을 활성화합니다. 이 설정은 이 버킷 및 해당 액세스 지점에만 적용됩니다. AWS 액세스는 [모든 퍼블릭 액세스 차단]을 활성화하도록 권장하지만, 이 설정을 적용하기 전에 퍼블릭 액세스가 없어도 애플리케이션이 올바르게 작동하는지 확인합니다. 버킷 또는 내부 객체에 어느 정도 수준의 퍼블릭 액세스가 필요한 경우 확장 스토리지 사용 사례에 맞게 아래 개별 설정을 사용자 지정할 수 있습니다. 자세히 알아보기

모든 퍼블릭 액세스 차단

활성화

이 버킷의 개별 퍼블릭 액세스 차단 설정

버킷 정책

편집삭제

JSON으로 작성된 버킷 정책은 버킷에 저장된 객체에 대한 액세스 권한을 제공합니다. 버킷 정책은 다른 계정이 소유한 객체에는 적용되지 않습니다. 자세히 알아보기

이 버킷에 대해 퍼블릭 액세스 차단 설정이 활성화되어 있기 때문에 퍼블릭 액세스가 차단됩니다.

활성화된 설정을 확인하려면 이 버킷의 퍼블릭 액세스 차단 설정을 확인하세요. Amazon S3 퍼블릭 액세스 차단 사용에 대해 자세히 알아보기

복사

{
 "Version": "2012-10-17",
 "Statement": [
 {
 "Effect": "Deny",
 "Principal": {
 "AWS": "arn:aws:iam::286943186215:user/user01"
 },
 "Action": "s3:PutObject",
 "Resource": "arn:aws:s3::buckethj0729/\*"
 }
 ]
}

## 4.3. 종합 분석 및 최종 권한 평가

user01의 IAM 정책은 모든 S3 작업을 허용하지만, S3 버킷 정책은 user01의 s3:PutObject 작업을 거부한다. "명시적 Deny는 명시적 Allow를 재정의한다"는 원칙에 따라, s3:PutObject 작업은 user01에게 최종적으로 거부된다.

따라서, user01은 s3:PutObject를 제외한 모든 S3 관련 작업을 수행할 수 있다.

- user01이 수행할 수 있는 S3 작업 예시
  - S3 버킷 생성 : s3:CreateBucket
  - S3 버킷 목록 보기 : s3:ListBuckets
  - 특정 S3 버킷 내 객체 목록 보기 : s3:ListObjects (또는 s3:ListBucket)
  - S3 버킷의 객체 다운로드 : s3:GetObject
  - S3 객체 삭제 : s3:DeleteObject
  - S3 버킷 삭제 : s3:DeleteBucket
  - s3:PutObject를 제외한 나머지 모든 S3 작업
- user01이 수행할 수 없는 S3 작업 예시
  - S3 버킷에 객체 업로드 : s3:PutObject

## 5. 테스트 및 검증

실제 AWS 환경에서 user01의 자격 증명으로 다양한 S3 작업을 시도하여 위의 분석 결과를 검증하고자 한다.

```
명령 프롬프트
C:\Users\wez>aws configure
AWS Access Key ID [*****PTOX]: AKIAUFTZFRUTYZGEMNHJ
AWS Secret Access Key [*****MjDa]: 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
Default region name [ap-northeast-1]: ap-northeast-1
Default output format [None]: json
```

### 예시 1: S3 버킷 객체 목록 보기 (성공)

- 명령 : `aws s3 ls s3://my-test-user01-bucket/`
- 결과 : 성공적인 객체 목록 출력

```
C:\Users\wez>aws s3 ls s3://buckethj0729/
2025-07-29 10:37:57      186177 dog.jpeg
```

### 예시 2: S3 버킷 객체 다운로드 (성공)

- 명령 : `aws s3 cp s3://my-test-user01-bucket/sample.txt ./sample.txt`
- 결과 : 성공적인 파일 다운로드

```
C:\Users\wez>aws s3 cp s3://buckethj0729/dog.jpeg ./dog.jpeg
download: s3://buckethj0729/dog.jpeg to ./dog.jpeg
```

### 예시 3: S3 버킷에 객체 업로드 (실패)

- 명령 : `aws s3 cp upload_test.txt s3://my-test-user01-bucket/upload_test.txt`
- 결과 : An error occurred (AccessDenied) when calling the PutObject operation: Access Denied 오류

```
C:\Users\wez>echo "test txt" > test.txt
C:\Users\wez>aws s3 cp test.txt s3://buckethj0729/test.txt
upload failed: .\test.txt to s3://buckethj0729/test.txt An error occurred (AccessDenied) when calling the PutObject operation: User: arn:aws:iam::286943186215:user/user01 is not authorized to perform: s3:PutObject on resource: "arn:aws:s3:::buckethj0729/test.txt" with an explicit deny in a resource-based policy
```

## 6. 결론

본 분석 및 테스트를 통해 user01은 부여된 IAM 정책으로 인해 기본적으로 모든 S3 작업을 허용받았지만, S3 버킷 정책에서 s3:PutObject 작업이 명시적으로 거부되어 최종적으로 해당 작업은 수행할 수 없음을 확인할 수 있었다. 이는 AWS 정책 평가의 핵심 원칙인 **"명시적 Deny의 우선순위"**가 올바르게 적용되었음을 보여준다. 즉, user01은 객체 업로드를 제외한 모든 S3 버킷 및 객체 관리 작업을 수행할 수 있다.